

22-07-2025

28 July 2025

נספח אבטחת מידע - הצהרה

אני, _____, בעל/ת ת.ז. _____ מספר _____,

נציג/ה המורשה של בית התכנה _____, ע.מ.ח.פ. _____ מתחייב ומצהיר כלהלן:

הואיל ורשות המסים בישראל (להלן: "רשות המסים") ובכללה שע"ם (שירות עיבודים ממוחשבים) (להלן: "המערכת"), כפופה למספר רגולציות, הן בהיות המערכת חלק מתשתית מדינה קריטית של מדינת ישראל, הן בשל מאגרי המידע המצויים במערכת והן בשל רגישות הנתונים, בית התכנה מצהיר כי הובהרו לו חובותיו כמורשה גישה למערכת, והכל כמפורט בהצהרה זו.

רשות המסים ושע"ם מאפשרות לעסקים וחברות המנהלים בתי תוכנה ומפתחי תוכנה (להלן: "בית התכנה") המעוניינים להשתמש (בשירותי Application Programming Interface (להלן: "API") להעברה ו/או קבלת מידע מ/אל המערכת, ומבלי לגרוע מכלל התחייבויותיהם, בית התכנה או נציגיו מתחייבים לעשות שימוש על פי נהלי שע"ם (להלן: "נהלי שע"ם"), התיעוד שפורסם ע"י שע"ם והרשאותיה של שע"ם בלבד וכן מתחייבים שלא להשתמש במערכת או ב-API לשם פיתוח אוטומציות שאינן קשורות קשר ישיר לשימוש החוקי במערכת ובהתאם לנהלי שע"ם או רובוטים וכיוצ"ב, ללא אישור של שע"ם במפורש מראש ובכתב.

השימוש במערכות שע"ם מותנה בעמידה בהוראות בחוק הגנת הפרטיות תשמ"א 1981, תקנות הגנת הפרטיות (אבטחת מידע) תשע"ז-2017 וכן תיקון 13 לחוק הגנת הפרטיות.

רשות המסים ושע"ם שומרות לעצמן את הזכות לעדכן את נספח אבטחת המידע מעת לעת ובהתאם לצרכי המערכת.

נציג בית התכנה

1. בית התכנה מתחייב לחתום ולהחתים את עובדיו המועסקים על ידו ו/או כל מי מטעמו (להלן: "נציג בית התכנה") על כתב סודיות ולהציגו על פי דרישת שע"ם. בית התכנה לא יעניק גישה למידע האישי לנציג בית התכנה בטרם החתים אותו על כתב הסודיות כאמור לעיל המותאם לאופי תפקידו ולשירות אותו הוא מעניק באמצעות המערכת.
2. על בית התכנה חלה האחריות כי נציג בית התכנה ישתמש בשירותי המערכת לפי נהלי שע"ם תוך שמירה על החוקים השונים הנוגעים לביצוע עבודתו אל מול המערכת. בית התכנה מצהיר כי יעניק גישה למערכות רק לנציגי בית התכנה שקיבלו הרשאה ספציפית לכך ואשר תפקידם מחייב גישה למידע האישי על בסיס הצורך לדעת (Need to Know).
3. בית התכנה מצהיר כי ידוע לו כי חלה עליו האחריות לכל שימוש במערכת באמצעות צד ג' עימו הוא התקשר לצורך כל פעולה עבורו או מטעמו.

הדין והרגולציה החלים

בית התכנה מצהיר ומתחייב כי בעת כל שימוש מכל סוג שהוא (ישיר או עקיף) במערכת הוא יעמוד בהוראות כל דין החל עליו ובכלל זה בהקשרי אבטחת מידע, הגנת פרטיות והגנת סייבר מבלי לגרוע מכלליות האמור, בית התכנה מאשר כי יפעל על פי חוק הגנת הפרטיות, תשמ"א-1981 תקנות הגנת הפרטיות (אבטחת מידע), תשע"ז-2017 (להלן: "תקנות אבטחת מידע") (חוק המחשבים, תשנ"ה-1995 וכן תיקון 13 לחוק הגנת הפרטיות

שמירת סודיות

4. בית התכנה מתחייב לשמור בסודיות גמורה כל מסמך, מידע, פרטים ונתונים מכל סוג שהוא, המתקבלים מהמערכת, לא להעביר / להודיע / למסור / להביא לידיעת כל אדם שאינו מורשה לכך, כל ידיעה שתגיע אליו בקשר עם המידע המצוי במערכת.
5. ידוע לבית התכנה כי הפרת שמירת הסודיות מהווה עבירה, בין היתר על פי סעיפים 118 ו-119 לחוק העונשין, תשל"ז-1977, סעיף 142 לחוק מס ערך מוסף, תשל"ו-1975, סעיף 231א לפקודת המכס, סעיפים 231, 232 ו-234 לפקודת מס הכנסה [נוסח חדש], סעיף 105 לחוק מיסוי מקרקעין (שבח, מכירה ורכישה), תשכ"ג-1963, סעיף 50 לחוק מס רכוש וקרן פיצויים, תשכ"א-1961, סעיף 19ב לחוק מס קניה (טובין ושירותים), תשי"ב-1952 וסעיף 23 לחוק הגנת הפרטיות, תשמ"א-1981.

מידע אישי

6. בית התכנה וואו מי מטעמו מצהיר כי אין בהצהרה זו כדי להעניק לו כל זכות בקשר לשימוש במידע האישי המצוי במערכת. בית התכנה וואו מי מטעמו ינקוט באמצעים מקובלים בנסיבות העניין כדי לוודא שהגישה למידע האישי ולמערכת נעשית בידי מורשי הגישה, ובשים לב להיקף הגישה שניתנה להם.
7. למען הסר כל ספק יובהר כי כל שימוש במערכת לצרכים אישיים, לרבות שימוש בנתונים שיש לבית התכנה או נציגיו, עובדיו וכיוצ"ב גישה אליהם באמצעות האזור האישי של רשות המסים, או כל גישה/העתקה/שימוש אחר במידע אישי (להלן: "שימוש אסור") ע"י בית התכנה או נציגיו או מי מטעמו הינו בניגוד לדין ובית התכנה מתחייב אף לא לבצע, ואף לא לנסות לבצע, שימוש אסור.
8. בית התכנה לא יגלה מידע אישי שעובד עבור לקוח באמצעות המערכת לכל אדם או גוף ללא שליחת ייפוי כוח לרשות המסים, ועבור הלקוח המיוצג בלבד, למעט כאשר גילוי כאמור נדרש על פי דין או במסגרת הליך משפטי.

אירוע אבטחת מידע

9. בית התכנה יתעד כל מקרה בו התגלה אירוע המעלה חשש לפגיעה באבטחת המידע שיש בה כדי להשפיע על המידע האישי שבית התכנה מעבד ואשר מצוי במערכותיו. תיעוד כאמור יבוסס, ככל האפשר, על רישום אוטומטי.
10. בית התכנה וואו מי מטעמו מצהיר כי במסגרת הנהלים, הוא קבע גם הוראות לעניין התמודדות עם אירועי אבטחת מידע, לפי חומרה ומידת רגישות, בהתאם לדין החל, לרבות אך לא רק, תקנות אבטחת מידע. בית התכנה יקיים דיון אחת לשנה לפחות באירועי אבטחת מידע, ויבחן את הצורך בעדכון הנהלים בקשר להוראות התמודדות עם אירועי אבטחת מידע כאמור, והכל כנדרש על פי תקנה 11(ג) בתקנות הגנת הפרטיות.
11. בית התכנה מתחייב להודיע לרשות המסים בכתב מידע עם היוודע לו אודות כל מקרה של שימוש לרעה בשירותי המערכת ו/או במערכת ו/או בתשתיות. כמו כן בית התכנה מתחייב להודיע לרשות המסים בדבר אירוע אבטחת מידע או קיום חשש לאירוע אבטחת מידע.

התחייבות לביצוע מבדקי חדירה (PT - Penetration Test)

12. כל בית תוכנה המשרת מעל 10 לקוחות, המנפיקות חשבוניות דרך מערכות שעם, יבצע מבדק חדירה יזום (Penetration Test) בתדירות של אחת לשנה וחצי. בתי תוכנה כאמור, הפועלים כבר היום מול מערכות שעם, יבצעו את מבדק החדירות הראשון לא יאוחר מיום 31/12/25.
13. כל בית תוכנה המחזיק מעל 100 לקוחות, המנפיקות חשבוניות, יבצע מבדק חדירה יזום (Penetration Test) לא יאוחר מחודש ספטמבר 2025 ולאחר מכן בתדירות של אחת לשנה וחצי באופן שוטף.
14. רשות המסים שומרת לה את הזכות לחייב את בתי התוכנה לבצע PT יזום, כאשר עולה חשד לפעילות חשודה ו/או לא תקינה המסכנת את רשות המסים בהיבטי סייבר.
15. על הגוף המבצע את מבדקי החדירה להיות בעל ניסיון של לפחות 3 שנים ברציפות בביצוע מבדקי חדירה בכמות של לפחות 25 מבדקים בשנה, בגופים גדולים המשרתים לפחות 500 לקוחות כל אחד.
16. על בית התוכנה לבצע תיקון לממצאים ברמת "High" או "Critical" בתוך 30 ימי עסקים מיום זיהוי החשיפה ולדווח לרשות המסים על טיפול בממצא – על חשבון בית התוכנה.

תהליכי אימות

17. יש לוודא כי בית התוכנה מחייב את לקוחותיו על מימוש מנגנון אימות דו-שלבי (2FA) לפי עקרון: Something you know (מה שבית התוכנה וואו מי מטעמו יודע) + Something you get (מה שבית התוכנה וואו מי מטעמו מקבל בזמן אמת)
18. יש לוודא כי נתוני האימות נשמרים באופן מוצפן כולל: \Client Secret\Access Token\Refresh Token\Password\JWT\ Session_Id וכדו'

ניטור ובקרה Audit שעל בית התוכנה לממש בהיבטי הזהדות:

19. על בית התוכנה לוודא כי הלוגים, בתהליכי האימות והזהדות, נשמרים באופן מאובטח ומוצפן (Data At rest) לתקופה של 12 חודשים.
20. על בית התוכנה ליידע, לדווח ולהתריע בזמן אמת על כל ניסיון תקיפה או התחזות אשר עלול להשפיע ולפגוע בממשקים של לקוחותיו אל מול רשות המסים (Fishing) של לקוחותיו, או כל ניסיון תקיפה אחר שהופעל כנגד בית התוכנה,

תחקור

21. בית התכנה מאשר ומצהיר כי ידוע לו כי רשות המסים שומרת לעצמה את הזכות לתחקר לוגים, אירועים וכיוצ"ב באתר בית התכנה.
22. בית התכנה מצהיר כי נכון למועד החתימה על נספח זה, לא ידוע לו כי מתנהלת כנגדו ו/או כנגד מי מטעמו ו/או כנגד מי ממנהליו כל תביעה או הליך משפטי בנושא הגנת הפרטיות ואבטחת המידע, לרבות הליכי פיקוח ו/או אכיפה מצד הרשות להגנת הפרטיות (להלן: "ההליכים"). במקרה של פתיחת אחד מההליכים, על בית התכנה להודיע ללא דיחוי לרשות המסים.

בתי תכנה יקרים, בכל שאלה או הבהרה, ניתן ליצור קשר עם מרכז התמיכה לשירותי API. ניתן גם לפנות לשירות

הלקוחות בטלפון 02-5688444 או בכתובת דוא"ל APISupport@taxes.gov.il

"אם יש ספק אין ספק"

אני _____ בעל/ת ת.ז. מספר _____ נציג/ה המורשה של בית התכנה, מאשר כי קראתי והבנתי את כל החובות החלות עלי כאמור לעיל. עוד ידוע לי ולא תשמע כל טענה מצידי כי ככל שרשות המסים ו/או נציגי המערכת ימצאו כי בית התכנה או נציגיו אינם עומדים באחת מן הדרישות הנ"ל, רשות המסים והמערכת שומרות את הזכות לנתק אותנו מהמערכת בכל עת, ולפעול בכל אמצעי משפטי אשר יידרש בנסיבות.

חותמת + חתימה _____